



cyber protection & response

WIFI SECURITY EXPOSED

An introduction to WIFI Security

Version: 1.2a

Date: 15/02/2018

Author: Sylvain Martinez

Reference: ESC2-MUSCL

Classification: Public

CONTENTS



- What is WIFI
- How WIFI Works

- Protocol
- Weaknesses
- Attacks

- Protocol
- Weaknesses
- Attacks

- Introduction

- Karma Attack
- Evil Portal

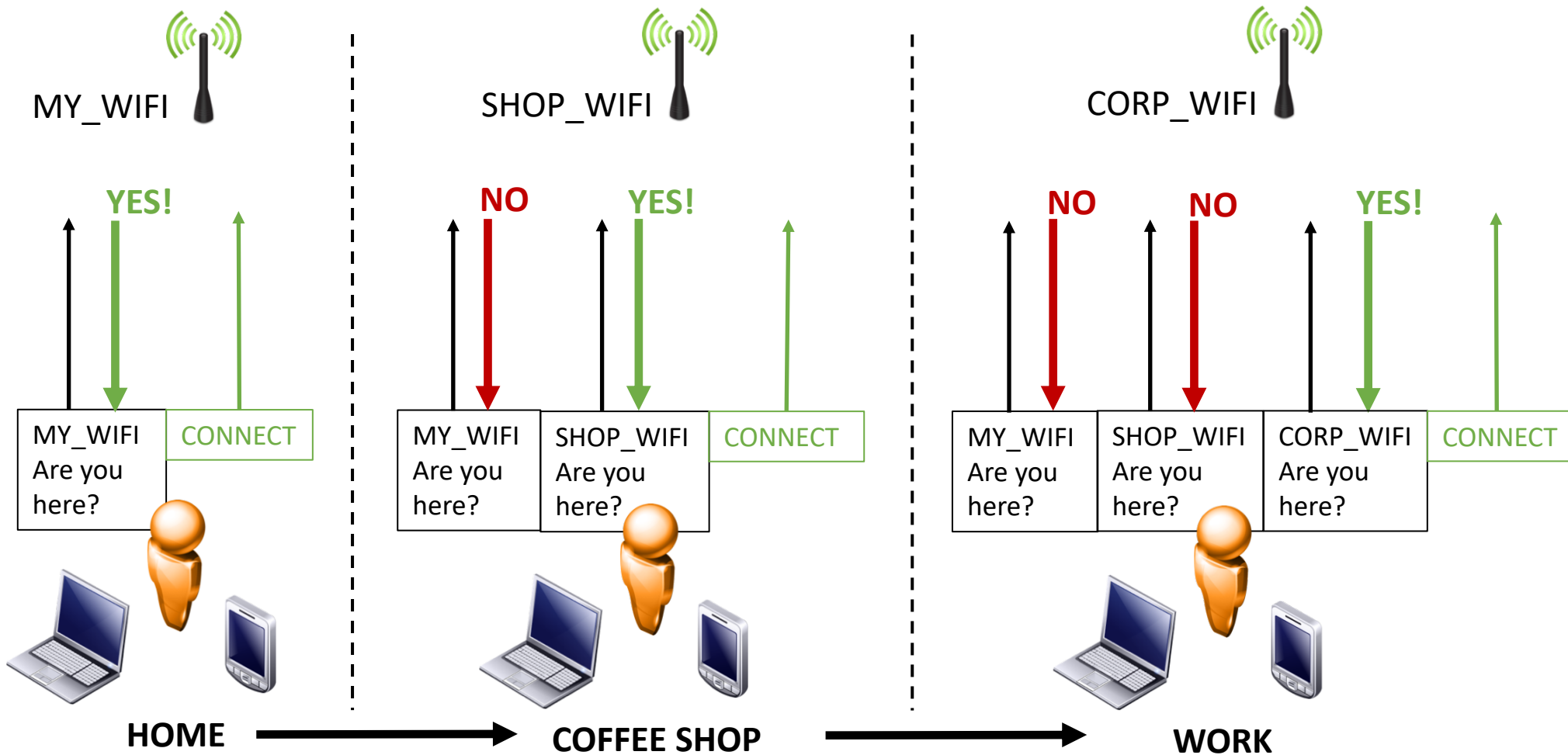
What is WIFI / WI-FI

- Technology using radio waves to provide network connectivity based on the IEEE 802.11 standard;
- Frequencies of 2.4 GHz and 5.8 GHz;
- 802.11a, 802.11b, 802.11g, 802.11n, 802.11ac
- Other radio waves technologies include:
 - ZigBee (IEEE 802.15.4);
 - Bluetooth and Bluetooth Low Energy (802.15.1);
 - WiMax (IEEE 802.16)
 - But also Cellular, NFC, etc;

HOW WIFI WORKS

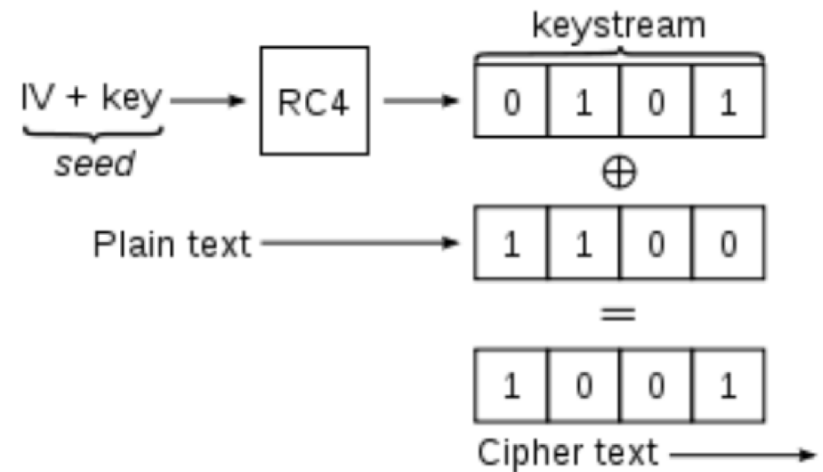
- HOTSPOTS will usually advertise there are here by BROADCASTING their name (SSID);
- Clients attempts to connect to HOTSPOTS, for example your WIFI home router;
- Connection to the HOTSPOT can be done:
 - With no password (OPEN);
 - With a password or passphrase;
 - With a certificate;
- Clients will remember HOTSPOTS they previously connected to: MY_WIFI, SHOP_WIFI, CORP_WIFI, etc.
- As long as the Clients WIFI is on, they will keep trying to connect to their known HOTSPOTS, all of them, all the the time.

HOW WIFI WORKS



WEP PROTOCOL

- 1997
- Wired Equivalent Privacy;
- 10 or 26 Hexadecimal digits (40 or 104 bits) + 24 bits IV key. 2 key sizes due to earlier USA restriction on cryptography exportation
- RC4 Stream cipher with CRC checks;



WEP WEAKNESSES

- Same key must never be used twice, this is a problem in a busy network with only a 24 bits IV key;
- Possibility to force traffic noise if the network is not busy enough;
- Possibility to modify intercepted packets and replay those into the network;
- Short key;
- CRC was not designed for security;
- Authenticated users can see other users' network traffic.

WEP ATTACKS

- 2001, passive attack to recover the RC4 Key in about a minute with the right conditions and equipment;
- 2005, Start of widely available open source tools to attack WEP;
- 2006, near real time decryption of WEP traffic;
- 2008, PCI Security Standards prohibits the use of WEP
- Popular attacking tools:
 - Aircrack, Aircrack-ng, kismet, Cain & Able, Fern WiFi Wireless cracker, etc.

WPA PROTOCOL

- WEP Replacement from 2003;
- Use of a Temporal Key Integrity Protocol (TKIP) to replace RC4
- Use of a Message Integrity Code (MIC/Michael)
- Dynamically generates 128-bit key for each packet
- Message Integrity Check to prevent replay and modification attacks;
- Designed as an interim solution for hardware not supporting WPA2

WPA WEAKNESSES

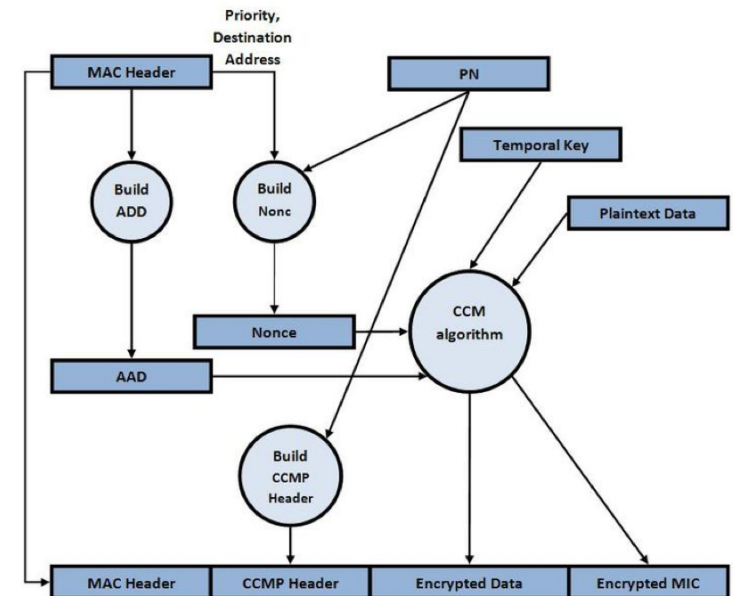
- Some common weaknesses to WEP regarding its message integrity check algorithm (TKIP);
- The message integrity code hash function (Michael) is flawed;
- Possible to retrieve the keystream to use for re-injection and spoofing;
- Authenticated users can see other users' network traffic.

WPA ATTACKS

- 2012, Possible to brute force the WPA key;
- $\text{Key} = \text{PBKDF2}(\text{HMAC-SHA1}, \text{passphrase}, \text{ssid}, 4096, 256)$;
- Large rainbow tables available for the top 1000 used SSIDs;
- WPS can be attacked through a weaker PIN strength;
- Popular attacking tools:
 - Aircrack-ng, Reaver, kismet, etc.

WPA2 PROTOCOL

- More secure protocol from 2004;
- Implements all the mandatory elements of IEEE 802.11i;
- Support for Counter Mode CBC-MAC (CCMP), an AES-Based encryption mode with strong security;
- Since March 2006 mandatory for all new WI-FI labelled devices.



WPA2 WEAKNESSES

- AES-128 is breakable with enough time;
- ARP Poisoning and Spoofing are possible;
- Authenticated users can see other user's network traffic;

WPA2 ATTACKS

- Possible to disconnect legitimate users with a DEAUTH attack, even when not associated to the network;
- Password can be cracked offline from intercepted encrypted traffic;
- 2017, Key Reinstallation AttaCKs (KRACKs) allows an attacker to intercept and read data that is encrypted. The main attack is against the 4 way WPA2 handshake.

<https://www.krackattacks.com>

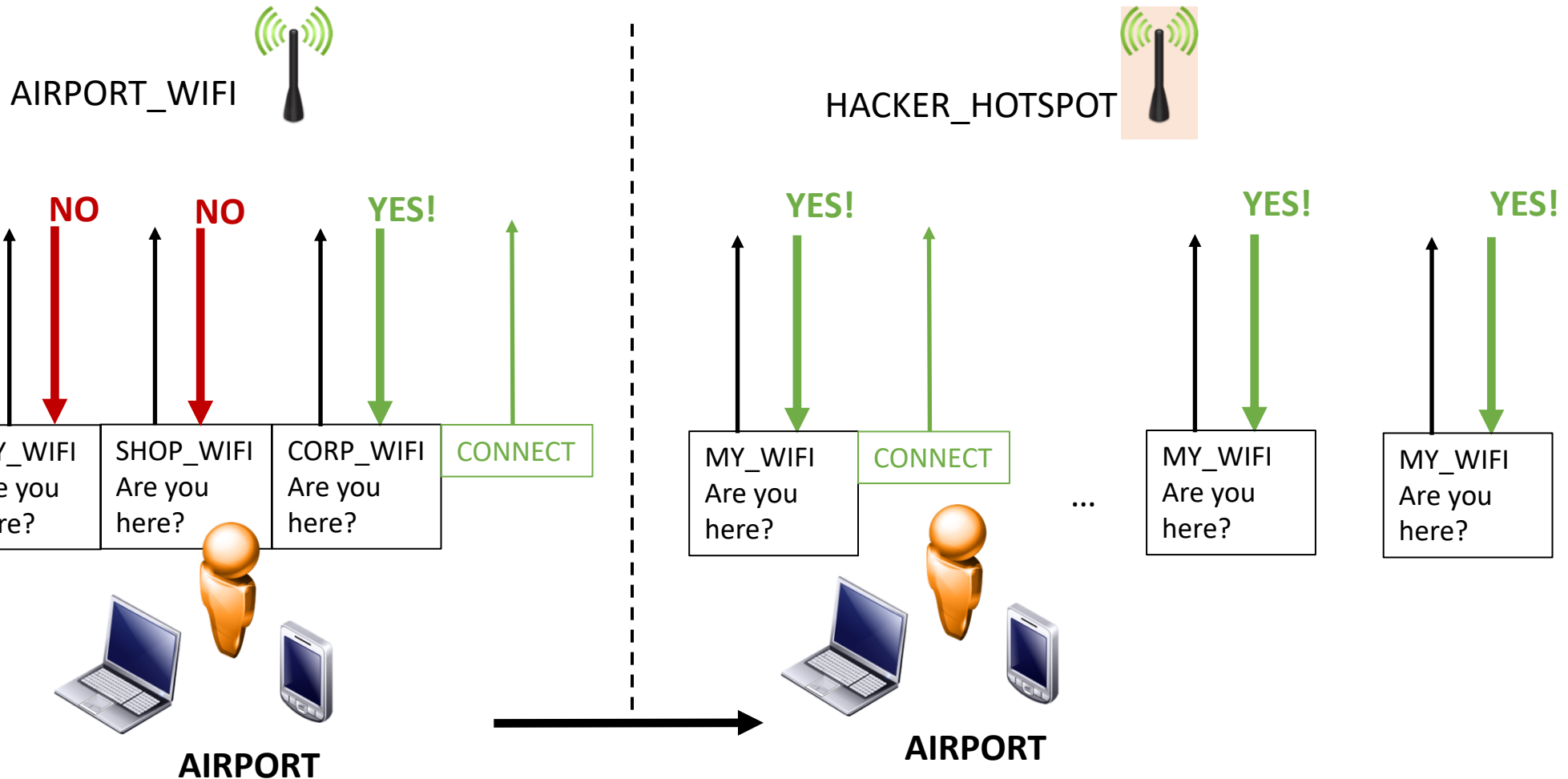
WPA3

- Announced in January 2018 for later this year;
- 192 bit encryption;
- Individualized encryption for each user;
- Protection against brute-force dictionary attacks;
- Improved handshake protocol
- Simpler connection without a GUI (WPS?)

DEMO

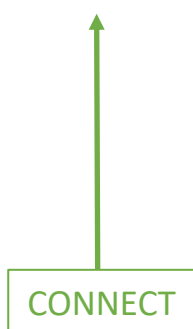
- KARMA ATTACK
- EVIL PORTAL

WIFI KARMA ATTACK



WIFI EVIL PORTAL ATTACK

FREE_WIFI



Please login



Hotel Page
Google
Orange
Etc.

Google
Creds



THANK YOU!

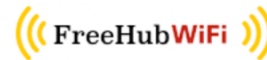
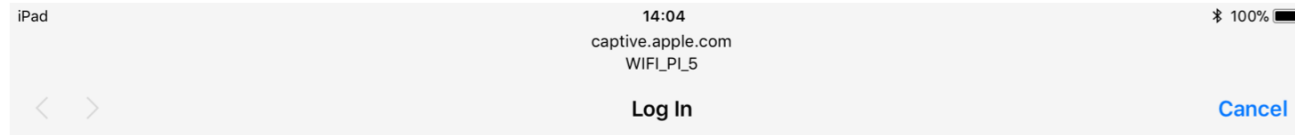


Internet Access Granted



COFFEE SHOP

WIFI EVIL PORTAL ATTACK



Welcome to this free public sponsored WIFI Hotspot

Terms and Conditions apply as described at the bottom of this page.
If you agree to proceed please use this service responsibly

I agree

PUBLIC WI-FI ACCESS TERMS AND CONDITIONS

This agreement sets out the terms and conditions on which wireless internet access (the Service) is provided free of charge to you by the WIFI hotspot provider (here on referenced as the "hotspot provider"). Your access to the Service is completely at the discretion of the hotspot provider. Access to the Service may be blocked, suspended, or terminated at any time for any reason including, but not limited to, violation of this Agreement, actions that may lead to liability for the hotspot provider, disruption of access to other users or networks, and violation of applicable laws or regulations. The hotspot provider reserves the right to monitor and collect information while you are connected to the Service and that the collected information can be used at discretion of the hotspot provider, including sharing the information with any law enforcement agencies, or anyone else. The hotspot provider may revise this Agreement at any time. You must accept this Agreement each time you use the Service and it is your responsibility to review it for any changes each time. We reserve the right at all times to withdraw the Service, change the specifications or manner of use of the Service, to change access codes, usernames, passwords or other security information necessary to access the service. IF YOU DO NOT AGREE WITH THESE TERMS, INCLUDING CHANGES THERETO, DO NOT ACCESS OR USE THE SERVICE.

1. DISCLAIMER You acknowledge

that the Service may not be uninterrupted or error-free; that your device may be exposed to viruses or other harmful applications through the Service; that the service provider does not guarantee the security of the Service and that unauthorized third parties may access your computer or files or otherwise monitor your connection; that the service provider's ability to provide the Service without charge is based on the limited warranty, disclaimer and limitation of liability specified in this Section and it would require a substantial charge if any of these provisions were unenforceable; that the hotspot provider can at any point block access to Internet Services that they deem violate the acceptable terms of use outlined in 2.1. The service and any products or services provided on or in connection with the

WIFI EVIL PORTAL ATTACK

iPad

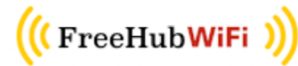
14:04
172.16.42.1
WIFI_PL_5

100%

< >

Log In

Done



Select your Mobile Provider for free sponsored WIFI
(You can also use your Google or Facebook account)

Provider:

Select your provider HERE

Username:

Password:

Sign-In

WIFI EVIL PORTAL ATTACK

iPad 14:04 172.16.42.1 WIFI_PL_5 100%

< > Log In Done

FreeHubWiFi

Select your Mobile Provider for free sponsored WIFI
(You can also use your Google or Facebook account)

Provider:

Select your provider HERE

- Select your provider HERE ✓
- GOOGLE
- FACEBOOK
- AT&T Mobility
- BT Openzone
- EE
- O2
- Orange
- Sky
- Sprint
- Three

WIFI EVIL PORTAL ATTACK

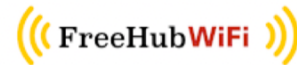
iPad 100%

172.16.42.1
WIFI_PL_5

< >

Log In

Done



Select your Mobile Provider for free sponsored WIFI
(You can also use your Google or Facebook account)

Provider:

GOOGLE

Username:

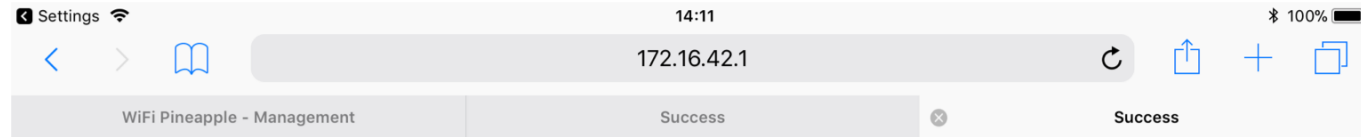
userid1@gmail.com

Password:

••••••

Sign-In

WIFI EVIL PORTAL ATTACK



Success

You can now access the Internet for Free!
Close this window to start.

WIFI EVIL PORTAL ATTACK

The screenshot displays the WiFi Pineapple Management web interface. The browser address bar shows the URL `172.16.42.1:1471`. The interface is divided into three main sections:

- p0f**: This section shows the status of the p0f tool. It includes a "Start" button and a dropdown menu. Below the button, it states "p0f is not running...".
- PineAP**: This section contains configuration options for the PineAP daemon. It includes checkboxes for "MK5 Karma", "Log: Probes", "Associations", "PineAP Daemon", "Send Beacon Responses", "Harvest SSIDs", "Dogma", and "Autostart [config]".
- Logs and Reporting**: This section displays the contents of the file `/sd/web/auth.log`. It shows a list of login attempts, including one for "Google, userid@google.com, thisisate" and another for "Google, userid1@gmail.com, secret1".

THANK YOU!